

Arquitetura Zero Trust

Fundamentos, componentes, aplicações e desafios

David Lobo Pedro Rosa Esteban Yopez

Universidade do Minho
Sistemas de Comunicações e Redes

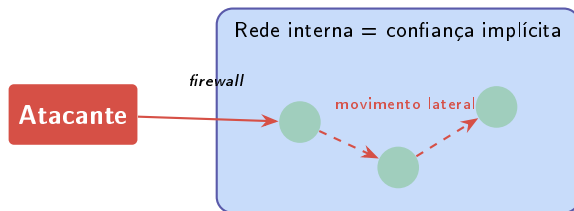
06/10/2026

Objetivos

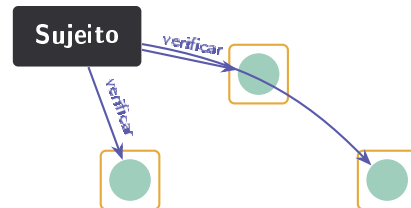
- Perceber **porque** o modelo de segurança baseado em perímetro deixou de ser suficiente
- Clarificar o que significa **confiança** no paradigma *Zero Trust*
- Descrever o **modelo lógico do NIST** (SP 800-207) e os seus pilares técnicos
- Analisar **domínios de aplicação** e **desafios** de implementação

Do perímetro ao *Zero Trust*

Modelo de perímetro



Zero Trust



cada recurso é protegido;
sem zona de confiança implícita

Ideia central

“Nunca confiar, verificar sempre” (Kindervag, 2010), consolidado pelo NIST na SP 800-207 (2020): deixa de existir distinção entre utilizadores internos e externos.

Exemplo prático: *BeyondCorp* (Google)

- Elimina a **rede corporativa privilegiada**
- Acesso **autenticado, autorizado e cifrado**, segundo o dispositivo e o utilizador
- Implementado por completo em **2017**; manteve-se seguro com o teletrabalho (COVID-19)



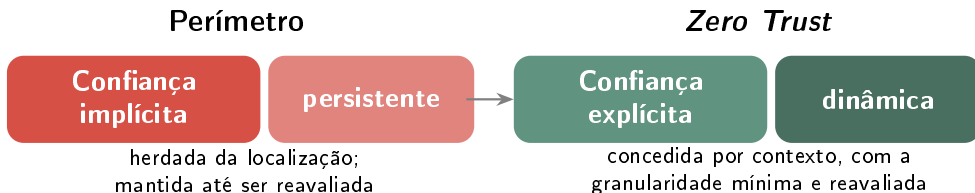
Ideia

O acesso depende da **identidade** e do **contexto**, não da **localização na rede**.

O conceito de confiança

Definição clássica (Rousseau et al.)

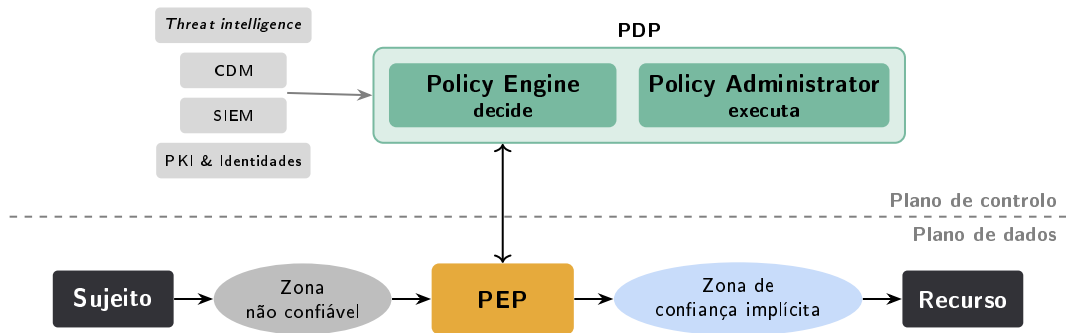
Estado psicológico que inclui a intenção de **aceitar a vulnerabilidade**, com base em expectativas positivas sobre o comportamento de outrem.



“Zero” não é ausência de confiança

É **zero confiança implícita**: a confiança passa a ser explícita, contextual e sujeita a avaliação constante.

Modelo lógico do NIST



- O **PEP** aplica a decisão junto ao recurso; o **PDP** decide com base num *algoritmo de confiança*
- A **zona de confiança implícita** deve ser tão pequena quanto possível

Pilares técnicos e avaliação contínua

Autenticação de identidade

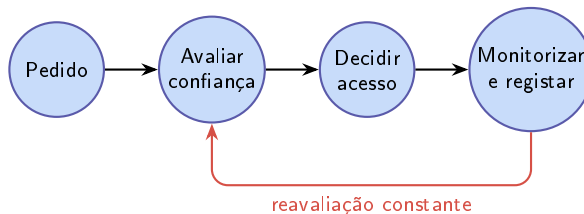
utilizadores e dispositivos; MFA

Controlo de acesso

menor privilégio;
RBAC, ABAC;
micro-segmentação

Avaliação de confiança

valor de confiança
dependente do contexto



A confiança **nunca** é definitiva: *machine learning*, lógica difusa e outros métodos recalculam o risco dinamicamente.

Domínios de aplicação

Acesso remoto

Teletrabalho e BYOD: acesso decidido por identidade, dispositivo e contexto, com menor privilégio.

Entidades externas

Acesso por sessão, limitado no tempo e aos recursos necessários, com registo e auditoria.

Ransomware

A micro-segmentação dificulta a propagação lateral do ataque.

Estudo de caso: IoMT

Dados sensíveis, dispositivos com poucos recursos e resposta em tempo real: um cenário que põe a ZTA à prova (autenticação leve nos dispositivos, orquestrador *Zero Trust* no *edge* e na *cloud*).

Desafios de implementação

Latência

A verificação contínua acrescenta processamento a cada pedido.

Sistemas legados

Dificuldade em integrar MFA, micro-segmentação e APIs modernas.

Gestão de políticas

Políticas dinâmicas e granulares aumentam a complexidade operacional.

- Faltam medições de desempenho de ZTA em sistemas reais
- Em ambientes com recursos limitados (IoT, IoMT) o custo é ainda mais crítico

Conclusões

- A ZTA substitui a confiança **implícita** (da localização) por confiança **explícita**, contextual e reavaliada
- Assenta em **autenticação**, **controlo de acesso** e **avaliação contínua** de confiança
- Reduz a superfície de ataque e limita o movimento lateral
- Persistem desafios: **latência**, **sistemas legados** e **complexidade** de gestão